SECURITY NINJA GERMANY



Incident investigations and threat hunting with Microsoft Sentinel Graph



Global Product Engineer - Microsoft Security DevOps at SoftwareOne, Microsoft Security MVP, MCT

MVP Microsoft® Most Valuable Professional

Microsoft CERTIFIED TRAINER MCT

20 OCT 2026 | Microsoft Germany HQ · Munich

secninjas-germany.com

Thank you to our Sponsors!

Host Partner

Microsoft

Gold

glueck kanja

water IT Security & Defense

robopack

PROACT

Silver

WORKSIMPLE EINFACH ARBEITEN

semperis

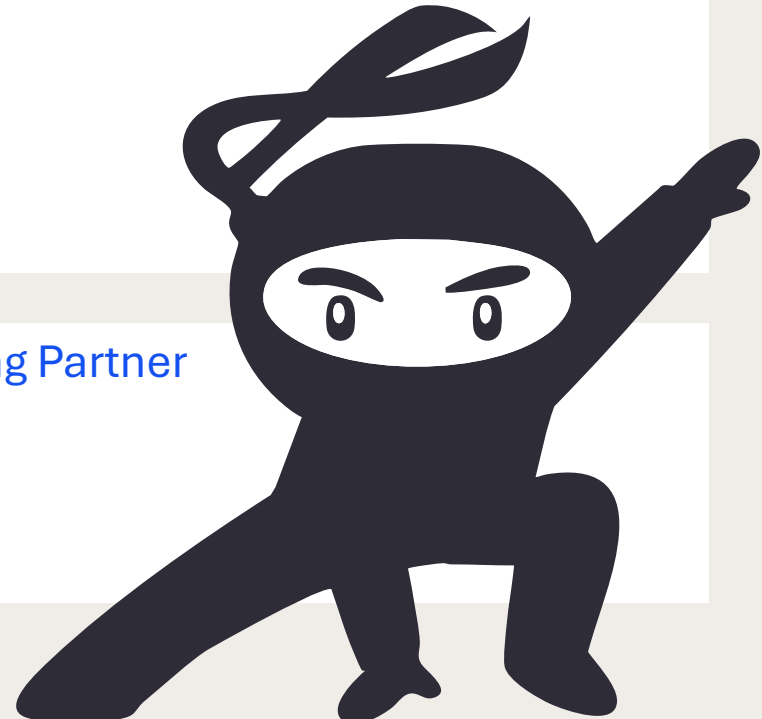
Bronze

ugurlabs

IC CONSULT

Snacks & Networking Partner

SCE



SECURITY NINJA GERMANY

SPEAKER

Uros Babic



Microsoft® MVP Most Valuable Professional

Microsoft CERTIFIED TRAINER MCT

Global Product Engineer — Microsoft Security DevOps

I'm a Global Product Engineer for Microsoft Security DevOps at SoftwareOne's Global Center of Excellence, where I help design and innovate MXDR for Microsoft Sentinel and strengthen our Managed SOC capabilities through security automation, incident response engineering and SOC-as-code development.

With 20+ years in cybersecurity, I focus on Azure-based security architecture, CI/CD automation and large-scale SecOps engineering using Bicep, Terraform and GitHub Actions.

As a Microsoft Security MVP and Microsoft Certified Trainer, I share what I learn at community events and conferences — mostly Microsoft Defender, Sentinel and AI-driven security automation.

AGENDA

What we'll cover

01	What the identity attack graph is
02	How the identity attack graph works
03	Prerequisites and setup
04	Explore, query and validate Use cases, graph controls and Fabric graph
05	Live demo: investigate and hunt
06	Questions and answers

40 minutes · 10:55 – 11:35 · Washington

SECURITY NINJA GERMANY

OVERVIEW

What is the identity attack graph?

PREVIEW

The identity attack graph visualizes how identities connect to Azure resources through permissions and group memberships.

What resources could an attacker reach if this account is compromised?

Which identities have indirect paths to privileged roles?
Which service principals can reach VMs, and via how many hops?

SOC analyst use Graph Query Language (GQL) to uncover hidden risks :

- Surface lateral movement paths: Find all routes an attacker could take from a compromised identity to reach critical resources
- Identify overprivileged accounts: Discover identities with excessive permissions or indirect paths to privileged roles
- Prioritize remediation: Focus on the shortest paths to your most sensitive assets

KQL is great when I want to understand what happened, excellent for searching and analyzing events over time, such as sign-ins, alerts, audit logs, and activity logs. GQL becomes powerful when I want to understand how things are connected and where an attacker could potentially go next

HOW IT WORKS

Asset data, modelled as three things

Identities

Users, service principals, managed identities and groups

Resources

Subscriptions, resource groups, VMs, storage accounts and Key Vaults

Access relationships

Role assignments and group memberships that create paths to the resources they can access

Illustrative: user → group → subscription → Key Vault. Confirm actual edges in Schema.

Prerequisites

Requirement	Details
Microsoft Sentinel data lake	Must be enabled. The graph reads from the data lake tier.
Microsoft Entra ID Assets connector	Required: users, groups, service principals, managed identities and their relationships.
Azure Resource Graph connector	Required: Azure subscriptions and resource hierarchy.
Role to create the graph	Global Administrator or Security Administrator.

When ARG enabled, its managed identity is automatically granted the Reader role only on subscriptions where you have the Owner role.

If you don't have Owner across your entire Azure estate the connector ingests a partial view. The graph gets built, but it won't include resources from subscriptions the managed identity can't read.

Install or update the required connectors. Confirm you have permission to turn on or update BOTH.

Asset data snapshots are taken once every 24 hours. After enabling a connector, data can take up to 24 hours to arrive in data lake. Initial graph processing after that can take up to 48 hours.

USE CASES

Five investigation use cases

1	**Attack path discovery** Potential routes from a compromised identity to a sensitive Azure resource.
2	**Blast-radius analysis** Potential reach of users, groups, service principals or managed identities.
3	**Over-privileged identity detection** Review broad assignments: subscription Owners, service principals and guest users.
4	**Privileged access review** Check whether access is direct or inherited, expected or suspicious.
5	**Incident response and threat hunting** Correlate suspicious sign-ins, escalation and service principal abuse with logs.

Bound the query, not the conclusion

DOCUMENTED STARTER · ONE DIRECTED HOP

```
MATCH (x)-[y]->(z)
RETURN * LIMIT 100
```

finds any source node (x), its outgoing relationship (y), and the connected destination node (z). RETURN * LIMIT 100 returns the first 100 matches.

Up to 100 matches

Source → edge → target matches.
Not the entire graph or all paths.
Default LIMITs also cap predefined results.

Adapt, then expand carefully

Edit a predefined query using Schema.
Raise LIMIT incrementally; removing it can affect performance and readability.

INVESTIGATION WORKFLOW

Schema first. Query. Then validate.

1

Inspect Schema

Confirm entity types, relationship direction and properties before writing GQL.

2

Run a bounded query

Start with a predefined query; edit it, highlight the intended query and run it.

3

Validate the result

Read node metadata and Table output. Check LIMIT before calling results complete.

The schema defines what you can match in GQL. Node types include Entra users, groups, service principals, managed identities, Azure subscriptions, resource groups, VMs, storage accounts, and Key Vaults. Edge types include group memberships and role assignments. Checking the schema before writing queries saves time.

GRAPH EXPLORATION

Follow the next hop deliberately

Inspect the node

Select for metadata.
Hover to highlight links
and hide unrelated nodes.

Expand the next hop

Right-click Explore
connected assets to see
the next hop.

Ungroup selectively

Inspect group details.
Ungroup / Regroup only
the assets you need.

What the visual encodes

Color = type. Size / label priority = connectedness, not severity.
Filters narrow displayed types; they do not establish completeness.

RESULT VALIDATION

The table is your cross-check

Validate before you interpret

Inspect JSON

Select a Table row to read each cell’s underlying JSON.

Shape the output

RETURN controls custom columns and their order.

Check and export

Search / sort results; export CSV for follow-up analysis.

WHAT TO LOOK FOR

Four signals in the graph

Short paths to sensitive assets

Prioritize potential routes; hop count alone is not a risk score.

Broad service principal access

Indirect reach to VMs or Key Vaults, often left from old deployments.

Circular group memberships

If cycles appear in returned memberships, inspect each edge and its metadata.

Access beyond the apparent role

Illustrative: nested memberships may lead to a sensitive resource. Validate each edge.

Illustrative signals, not proven compromise. Review permissions and correlate activity.

Costs, access and readiness

BILLING AND DATA RETENTION

Asset data ingestion: charges apply for ingesting data through the Entra ID Assets and Azure Resource Graph connectors

Asset data retention: default retention is 30 days, expandable up to 12 years, and you pay for whatever period you configure

ACCESS AND READINESS

- Initial processing: up to 48 hours.
- Schema is Microsoft-managed
- ARG connector ingests partial coverage by default
- Preview behavior can change before GA.

Enable it well before you need it for an investigation.

CUSTOM GRAPHS · PREVIEW

Beyond the built-in: custom graphs

Requires: Sentinel data lake · VS Code extensions · read access to input data

```
Sentinel Data Lake
      ↓
Sentinel Spark Notebook
      ↓
Users + Groups
      ↓
MemberOf relationships
      ↓
Custom Graph
      ↓
GQL / Graph visualization
```

Model

Sentinel Spark notebook
Lake data → nodes / edges
Validate schema; build

Persist

Submit a graph job
On demand or scheduled
Publish a reusable graph

Investigate

Query with GQL
Defender → Sentinel → Graphs
Also: notebooks / query APIs

Built-in identity graph: no notebook required. Custom graphs use a separate authoring workflow.
Interactive = session-only. Published graph job = reusable.

Common scenarios

- Phishing email kill chain with enriched business context
- DNS C2 beacon hunter
- Behavioral attack chain detection
- OAuth privilege escalation

Model
Sentinel Spark notebook
Lake data → nodes / edges
Validate schema; build

Persist
Submit a graph job
On demand or scheduled
Publish a reusable graph

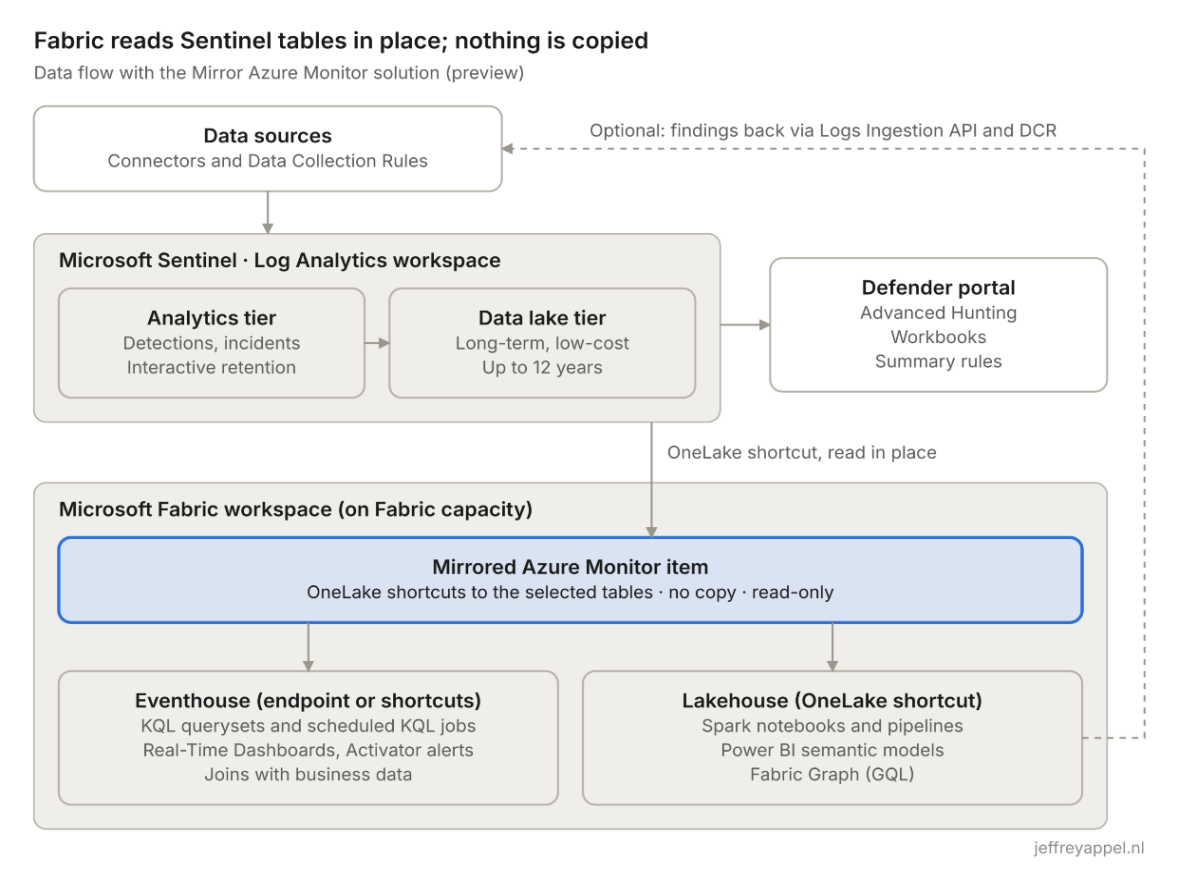
Investigate
Query with GQL
Defender → Sentinel → Graphs
Also: notebooks / query APIs

Built-in identity graph: no notebook required. Custom graphs use a separate authoring workflow.
Interactive = session-only. Published graph job = reusable.

Requires: Sentinel data lake · VS Code extensions · read access to input data

From Sentinel identity graph to Fabric Graph

Requires: Fabric workspace · Lakehouse tables · data mirroring or source access



Source:https://jeffreyappel.nl/how-to-integrate-microsoft-defender-sentinel-with-microsoft-fabric/

Fabric Graph model give relationships across Sentinel lake data in a Lakehouse and query them with GQL.

Think of users, devices, IPs and apps as nodes, and sign-ins or connections as edges, useful for blast radius and lateral movement analysis.

Live demo

Washington · 10:55 – 11:35

Investigate a potential access path

Understand the schema → Run a starter query → Inspect an identity → Explore connections → Validate results → Share findings

Check LIMIT and permissions. Correlate activity before concluding compromise.

Thank You, Ninjas!



Uros Babic · Global Product Engineer, Microsoft Security DevOps · SoftwareOne